

crest(data)

Technical Design Document
GTI For AWS Guard Duty

Version Control

#	Document Version	Date	Owner	Document Status	Comments
1	1.0.0	12/12/2025	Crest Data	Draft	

Contents

Version Control	2
Contents	2
1. Overview	4
1.1 Google Threat Intelligence (GTI) Platform	4
1.2 AWS GuardDuty	4
1.3 GTI integration for AWS GuardDuty	4
2. Compatibility Matrix	5
3. Assumptions	6
4. Architecture Diagram	7
System Design Diagram (logical description)	7
5. Integration Use Cases	8
Use Case: Retrieve and Update Threat Entity List	8
Acceptance Criteria	8
6. Technical Approach	9
6.1 Lambda ingestion flow (IOC Stream + Threat Lists)	9
High-level steps:	9
6.2 Checkpointing and pagination	10
6.3 S3 threat list format	10
6.4 Security (Secrets Manager, IAM)	11
7. GTI API Information	12
7.1 IOC Stream	12
7.2 Threat Lists	13
8. AWS Service Information	14
8.1 AWS Lambda	14
8.2 Amazon S3	14
8.3 AWS Secrets Manager	14
8.4 Amazon EventBridge	14
8.5 Amazon GuardDuty	14

8.6 Amazon CloudWatch Logs	14
8.7 AWS IAM	15
9. Error Handling	16
10. Limitations	17
11. Performance & Scaling Considerations	18
12. References	19

1. Overview

1.1 Google Threat Intelligence (GTI) Platform

Google Threat Intelligence (GTI), backed by VirusTotal data, provides curated threat intelligence such as indicators of compromise (IOCs) across IP addresses, domains, URLs, files and threat lists. GTI exposes REST APIs (e.g. IOC Stream and Threat Lists) to programmatically retrieve fresh IOCs for security integrations.

1.2 AWS GuardDuty

Amazon GuardDuty is a threat detection service that continuously monitors AWS accounts and workloads for malicious activity.

GuardDuty uses entity lists and IP address lists to customize threat detection within an AWS environment. Entity lists, the recommended option, support both IP addresses and domain names, whereas IP address lists support only IP addresses. Before creating and applying these lists, the required permissions must be configured based on the list type being used.

GuardDuty uses these lists in combination with AWS telemetry (VPC Flow Logs, CloudTrail, DNS logs, etc.) to generate findings when matching activity is detected.

1.3 GTI integration for AWS GuardDuty

This integration retrieves IOCs from GTI and publishes them into a single S3-hosted Threat Entity List, which GuardDuty uses during its detection cycles.

Key characteristics:

- Entity list is used (domains, wildcard domains, and IPv4 addresses).
- A scheduled Lambda function ingests IOCs from GTI, deduplicates them, updates the S3 list, and maintains a checkpoint to ensure incremental processing.
- GuardDuty automatically consumes the updated list from S3.

2. Compatibility Matrix

Component	Version / Type
GTI API	v3
AWS Lambda Runtime	Python 3.x (e.g. 3.12)
AWS GuardDuty	Any region supporting Threat Entity Lists
AWS S3	Standard S3 bucket
AWS Secrets Manager	Standard secret
Supported Browsers (console)	Chrome, Edge

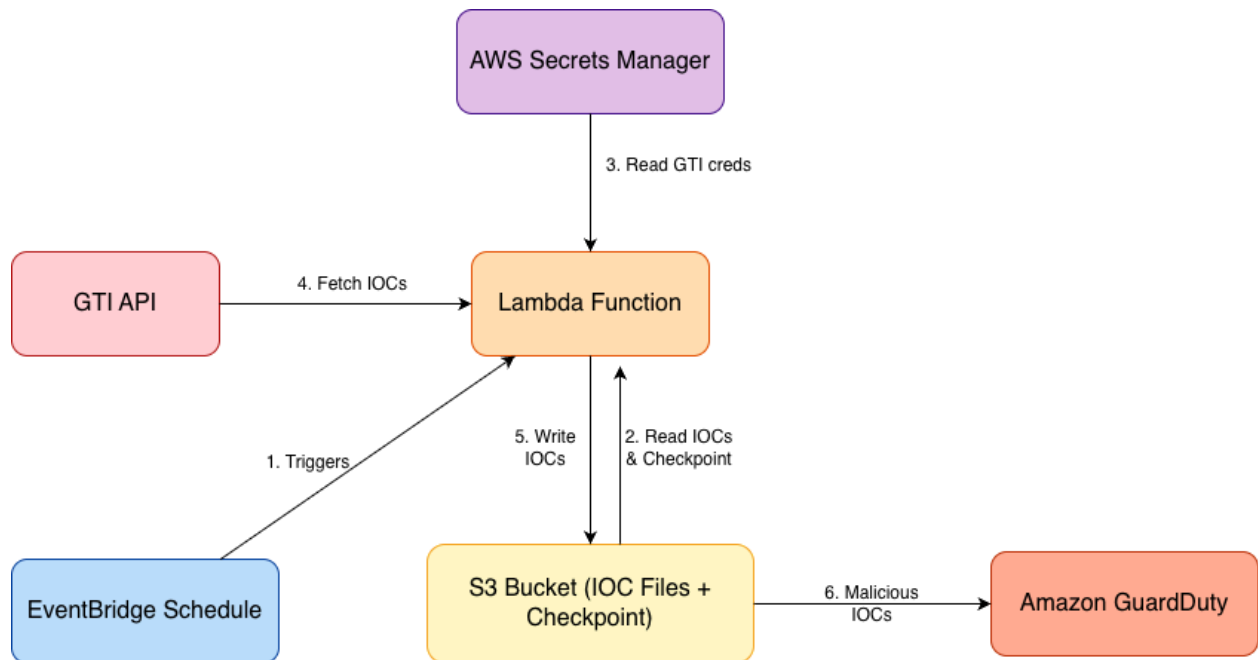
3. Assumptions

- An active GTI / VirusTotal subscription with access to IOC Stream and Threat Lists.
- An AWS account where CloudFormation can deploy all required resources.
- IAM permissions allow CloudFormation to create Lambda functions, S3 buckets and objects, IAM roles, EventBridge schedules, and Secrets Manager secrets.
- Outbound network connectivity from Lambda to GTI API endpoints (www.virustotal.com)
- A Secrets Manager secret exists (or will be created through CloudFormation) for the GTI API key.
- GuardDuty will reference the S3 file path for the Threat Entity List generated by this integration.

4. Architecture Diagram

System Design Diagram (logical description)

Flow (high level):



1. **EventBridge** triggers the ingestion Lambda on a scheduled interval.
2. Lambda loads configuration and retrieves the GTI API key from Secrets Manager.
3. Lambda reads the latest checkpoint and existing threat entity list from S3.
4. Lambda calls GTI IOC Stream and GTI Threat Lists APIs.
5. New IOCs (domains and IPv4 addresses) are parsed, deduplicated, and combined with existing entries. Lambda overwrites the updated **threat-entity.txt** file in S3 and updates the checkpoint file in S3.
6. GuardDuty automatically uses the refreshed entity list during its next internal evaluation cycle.

5. Integration Use Cases

Use Case: Retrieve and Update Threat Entity List

The integration periodically ingests GTI IOCs and maintains a consolidated S3-hosted **Threat Entity List** for GuardDuty.

Acceptance Criteria

- Lambda configuration must be fully controlled via environment variables (S3 bucket, keys, secret name, region, etc.).
- GTI API key must be retrieved only from Secrets Manager.
- Lambda must maintain an incremental ingestion checkpoint
- Only domain and IPv4 IOCs are ingested.
- Deduplication must ensure the S3 file contains unique entries.
- The threat entity list must follow GuardDuty's required plain-text, line-separated format.
- Lambda must handle pagination and checkpoint updates correctly.
- CloudWatch Logs must record counts, checkpoint values, and error details.
- GuardDuty must successfully load the updated threat entity list without formatting errors.

6. Technical Approach

6.1 Lambda ingestion flow (IOC Stream + Threat Lists)

- Language: **Python 3.x**
- Key components:
 - GTIClient class using urllib3 for reusable HTTP sessions.
 - Utility functions for S3 read/write and checkpoint management.
 - lambda_handler(event, context) orchestrating the full flow.

High-level steps:

- **Initialization**
 - Lambda loads CONFIG from environment variables.
 - AWS clients for Secrets Manager and S3 are instantiated with the configured region.
- **Secret Loading**
 - Lambda reads the *GTI API* key from Secrets Manager.
- **State Loading**
 - Load checkpoint (i.e. gti-checkpoint.json) from S3.
 - Load current IOC list (from S3) into in-memory **sets** to support O(1) deduplication.
- **Fetch from IOC Stream**
 - Builds the initial IOC Stream request:
 - If cursor is present → `?cursor=<cursor>&limit=40&order=date+`
 - Else if last_notification_date present →
`?filter=date:<ISO\_TIME>+&limit=40&order=date+`
 - Else → default (no filter, first page).
 - For each data item:
 - Reads notification_date and maintains last_date (max seen).
 - Add `ip\_address` and `domain` to respective lists
 - After the loop, writes checkpoint to S3 with:
 - cursor: last meta.cursor value (may be null).

- `last_notification_date`: latest notification date seen.
- **Fetch from Threat Lists**
 - Computes timestamp (UTC – 1 hour) in `YYYYMMDDHH` format.
 - Retrieves list of threat categories from `/threat_lists`.
 - For each category:
 - Calls `/threat_lists/{category}/{timestamp}?type=ip_address,domain``
 - Add ``ip_address`` and ``domain`` to lists
- **Write results**
 - `threat-entity.txt` with line-separated domains/IPs.
 - Files are overwritten after each run.
 - Rotate the file if file size exceeds 35mb.

6.2 Checkpointing and pagination

- Checkpoint file: `gti-checkpoint.json` in S3.
- Structure:

```
{
  "cursor": "eJwVy11v...",
  "last_notification_date": 1764754338
}
```

- Behavior:
 - **Within a single run**, the ***cursor*** is updated after each full page retrieval.
 - If Lambda fails mid-run, the next execution resumes from the last stored cursor.
 - When the final page has no cursor, `last_notification_date` is used next time for date-based filtering.

6.3 S3 threat list format

- `threat-entity.txt`:
 - One domain/IPV4 per line.
 - Supports wildcard patterns (eg. `*.example.org`).

- Supports CIDR (eg. 10.0.0.0/24)
- gti-checkpoint.json:
 - JSON object as described above.

6.4 Security (Secrets Manager, IAM)

- **GTI API key** stored in AWS Secrets Manager under a secret name referenced by **SECRET_NAME**.
- Lambda execution role must permit:
 - secretsmanager:GetSecretValue on the GTI secret.
 - s3:GetObject, s3:PutObject, s3:ListBucket on the target bucket.
 - CloudWatch Logs permissions (via AWSLambdaBasicExecutionRole policy).
- Optional: For production, IAM policies should be restricted to specific ARNs (bucket and secret)

7. GTI API Information

7.1 IOC Stream

- **URL:** https://www.virustotal.com/api/v3/ioc_stream
- **Method:** GET
- **Headers:**
 - x-apikey: <GTI_API_KEY>
 - accept: application/json
- **Query Parameters (used):**
 - cursor – resume token for pagination.
 - filter=date:<ISO8601>+ – filter by notification date.
 - limit – max number of items per page (e.g. 40).
 - order=date+ – ascending by date.
- **Response (simplified):**

```
{
  "data": [
    {
      "id": "1.2.3.4",
      "type": "ip_address",
      "context_attributes": {
        "notification_date": 1764754338,
        "indicators": [...]
      }
    }
  ],
  "meta": {
    "cursor": "eJwVy11v..."
  },
  "links": {
    "self": "...",
    "next": "https://www.virustotal.com/api/v3/ioc_stream?...cursor=..."
  }
}
```

7.2 Threat Lists

- **List categories:**
 - GET https://www.virustotal.com/api/v3/threat_lists
- **IOCs for category:**
 - GET https://www.virustotal.com/api/v3/threat_lists/{category_id}/{timestamp}?type=ip_address.domain
- **Headers:**
 - x-apikey: <GTI_API_KEY>
 - accept: application/json
- **Response (simplified):**

```
{
  "iocs": [
    {
      "data": {
        "id": "1.2.3.4",
        "type": "ip_address"
      }
    }
  ]
}
```

8. AWS Service Information

8.1 AWS Lambda

- Used as the core compute engine that orchestrates the GTI ingestion workflow.
- Lambda is triggered on a schedule (EventBridge) and performs integrations script
- Runs statelessly and maintains incremental progress using S3-based checkpointing.

8.2 Amazon S3

- Stores IOC files in plain text format and checkpoint used for cursor/date resumption.
- Lambda reads/writes S3 objects each run to maintain deduplicated IOC lists.

8.3 AWS Secrets Manager

- Securely stores the GTI API key required for authenticating calls to the GTI API.
- Lambda retrieves the secret at runtime using `secretsmanager:GetSecretValue`.
Prevents hard-coding credentials inside Lambda functions.

8.4 Amazon EventBridge

- Responsible for triggering the ingestion Lambda on a scheduled interval
- Ensures consistent, automated refresh of IOC files without manual intervention.

8.5 Amazon GuardDuty

- Continuously analyzes AWS traffic logs (VPC flow logs, CloudTrail logs, DNS logs) and generates findings when activity matches threat intel.
- Reads updated threat intel directly from S3 without needing explicit Lambda invocation.

8.6 Amazon CloudWatch Logs

- Automatically collects logs from Lambda, enabling debugging and audit visibility.
- Stores execution logs, error traces, API call failures, IOC counts, and checkpoint updates.
- Useful for troubleshooting ingestion failures or GTI API issues.

8.7 AWS IAM

- Manages permissions for Lambda, S3, Secrets Manager, and GuardDuty interactions.
- Lambda execution role includes the least-privilege access required for:
 - Reading secrets
 - Fetching/writing S3 objects
 - Writing CloudWatch Logs
- IAM ensures security boundaries between services are enforced correctly.

9. Error Handling

Typical error classes:

1. **Configuration / Env errors**

- Missing or empty required environment variables.
- Logged with clear messages indicating which variable is missing.

2. **Secrets Manager errors**

- `AccessDeniedException`: incorrect IAM permissions.
- `ResourceNotFoundException`: secret name incorrect or missing.

3. **GTI API errors**

- HTTP 4xx / 5xx from GTI APIs.
- Lambda logs error status and a truncated body for debugging (decoded safely).

4. **S3 errors**

- Missing S3 objects for the first run are treated as empty sets.
- Write errors log bucket + key + error message.

5. **GuardDuty configuration errors** (out of scope for Lambda, but for validation):

- If the threat list path or format is incorrect, GuardDuty console will show error; integration testing must verify this.

10. Limitations

- GuardDuty supports a maximum of six entity lists per account per region.
- The threat entity file must not exceed 35 MB.
- GuardDuty supports IPv4 only for IP entries.
- Large IOC volumes may require increased Lambda memory or timeout values.

11. Performance & Scaling Considerations

- Python set-based deduplication provides $O(1)$ average insertion.
- S3 overwrites are efficient for lists under a few MB.
- GTI pagination volume determines Lambda runtime.
- EventBridge frequency should respect GTI API rate limits.

12. References

- Google Threat Intelligence / VirusTotal API documentation (IOC Stream, Threat Lists).
 - IOC Stream :
<https://gtidocs.virustotal.com/reference/get-objects-from-the-ioc-stream>
 - Threat List :
 - Latest Threat List :
<https://gtidocs.virustotal.com/reference/get-latest-threat-list>
 - Hourly Threat List :
<https://gtidocs.virustotal.com/reference/get-hourly-threat-list>
- AWS documentation for:
 - Amazon GuardDuty entity lists and IP address lists configuration.
 - https://docs.aws.amazon.com/guardduty/latest/ug/guardduty_upload-lists.html#guardduty-threat-intel-list-entity-sets
 - <https://docs.aws.amazon.com/guardduty/latest/ug/guardduty-lists-create-activate.html>